Security Governance
08/06/2026

Family Name_____ **Name**_____ **Student ID**_____

Please, tick the appropriate option:

- ☐ Master of Science in Cyber Security
- ☐ Master of Science in Engineering in Computer Science
- ☐ Erasmus
- ☐ Other

Questions have all the same weight on the final mark. Questions will be evaluated according with the following evaluation criteria:

1. *Correctness of the answer*
2. *Completeness of the answer*
3. *Correct interpretation of the question*
4. *Clarity of the answer*
5. *Fitness of the answer*

Q1: Assess the truthfulness of every statement and provide a detailed motivation for your answer:

1	The depth dimension of the Von Solms model refers to horizontal business processes	T	F
2	Control activities exist only at the operational level	T	F
3	The operational level is primarily concerned with long-term security planning	T	F
4	Security governance is mainly executed at the operational level	T	F
5	Policies are typically defined at the tactical level.	T	F
6	Risk management focuses only on technical vulnerabilities and ignores business impact.	T	F
7	In the governance model, risk management helps prioritize security controls based on risk levels.	T	F
8	Risk management is a one-time activity and does not require continuous review.	T	F
9	In the governance model, awareness is only relevant at the operational level.	T	F
10	Security awareness focuses only on technical training for IT staff.	T	F

Q2: Assess the truthfulness of every statement and provide a detailed motivation for your answer:

1	STRIDE is a threat-modelling framework used to identify security threats in a system.	T	F
2	In STRIDE, the letter "S" stands for Security.	T	F
3	Information Disclosure threats are primarily concerned with preventing unauthorized modification of data.	T	F
4	Attack trees are graphical models that describe only the defensive controls implemented to protect a system.	T	F
5	In an attack tree, the root node typically represents the attacker's starting point.	T	F
6	Every branch in an attack tree must be successfully executed to achieve the attack goal.	T	F
7	STRIDE categories cannot be mapped to violated security properties such as confidentiality, integrity, authentication, authorization, and availability.	T	F

4. National and international standards, frameworks, and best practices (e.g., ISO 27001, COBIT, NIST CSF, GDPR, COSO, ISAE/SOC reports) that you would recommend adopting, explaining how they contribute to the organization's security governance objectives.

Q5: Consider the smart home network reported in Figure 1. Table 1 and Table 2 report the vulnerabilities for the different devices and their corresponding details. Table 3 reports the network reachability matrix for the smart home network.

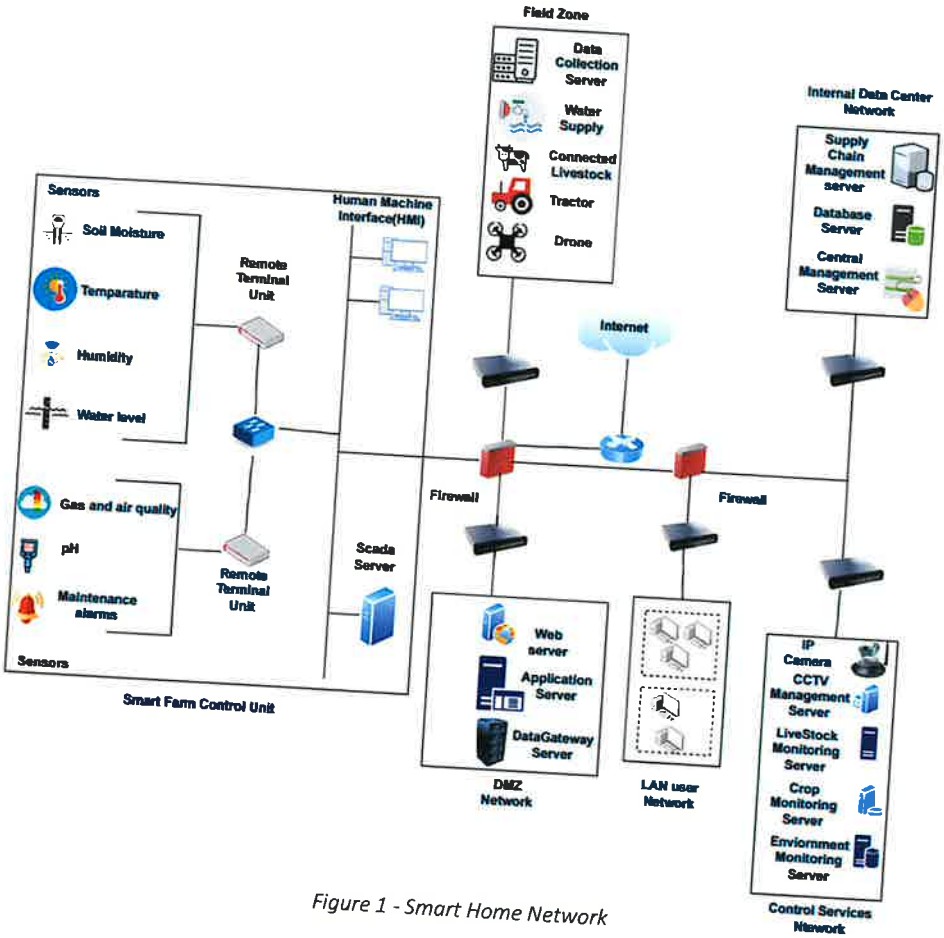


Figure 1 - Smart Home Network

Hosts	Vulnerability
LAN user (LU)	CVE-2018-15966
Web Server (WS)	CVE-2022-21908
Crop Monitoring Server (CRMS)	CVE-2021-35464
Environmental Control Server (ECS)	CVE-2017-12708
Application Server (APS)	CVE-2015-1920
Supply Chain Management Server (SCMS)	CVE-2022-23302
SCADA (SCA)	CVE-2021-40358 CVE-2014-8551 CVE-2016-5195
Drone (DR)	CVE-2021-34125 CVE-2023-47625
CCTV management Server (CCMS)	CVE-2018-17917
IP camera (IPC)	CVE-2013-1604
Livestock Monitoring Server (LMS)	CVE-2024-21686 CVE-2016-5195

Table 1 - Vulnerabilities list

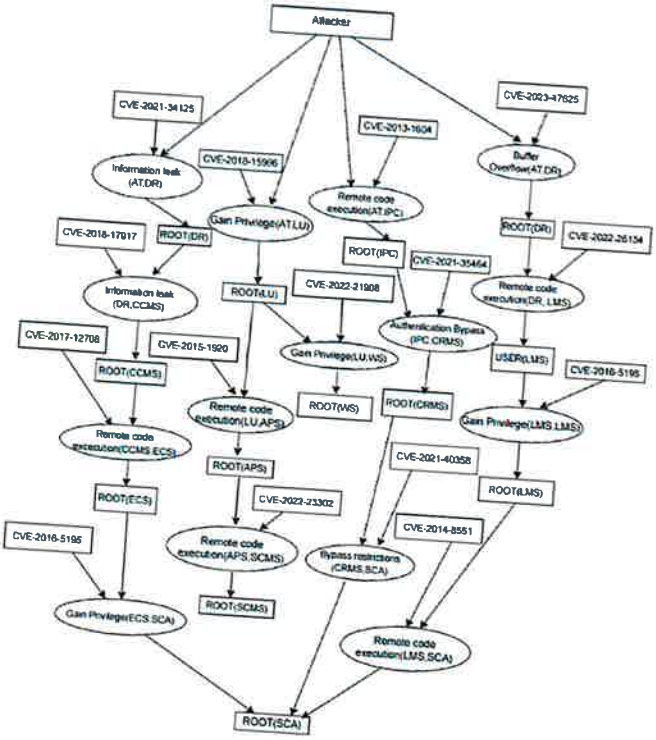


Figure 3– AG1 graphical representation

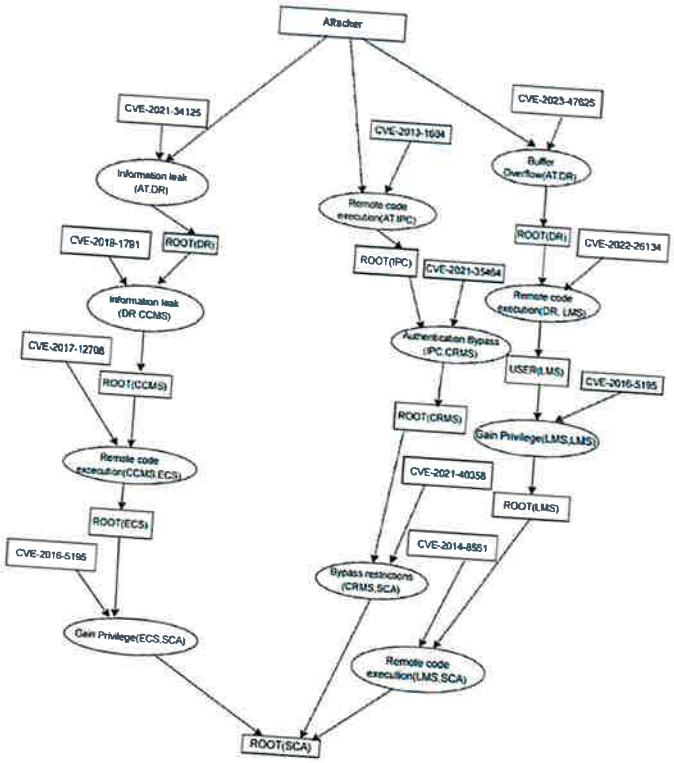


Figure 2 – AG2 graphical representation

Discuss how the use of AG2 instead of AG1 may influence the cyber-risk assessment of the network. In your answer, evaluate:

1. the benefits of reducing the attack graph size;
2. the information that may be lost during graph reduction;
3. the impact on attack-path discovery and risk estimation;
4. the trade-off between scalability and assessment accuracy.

Support your discussion with examples derived from the vulnerabilities, reachability matrix, and attack graphs provided.

According to the Italian law 675 of the 31/12/96, I authorize the instructor of the course to publish on the web site of the course results of the exams.

Signature: _____